Track A – “Venus Fly Trap”

CPT_S 428 Team

James Richards-Perhatch
Collin Bale
Mitchell Milander
Ethan Burzynski

Target

The target of this project will be ChatGPT 5.6 Luna and Ollama v0.34.0 using n8n as their agentic harness. The team will design a webpage for the models to crawl and collect information from. The webpage will be poisoned with compromising information and will act as the attack vector. The information on the webpage will secretly prompt the AI model to send an email containing a pre-determined flag. The success of this attack will be determined by the presence of the flag in the contents of the email. If the flag is present, we successfully compromised the AI model.

Threat

Who is the attacker? What access do they start with?

> In our scenario the attacker hosts a webpage. The attacker is performing a black box attack and is aiming for a widespread attack without a predetermined target. Consider this a “venus fly trap” approach to targeting victims.

What do they control? Be specific: a page the agent visits, a file the parser reads.

> The attacker only has control of a webpage that a victim’s AI agents might visit. They have multiple attack vectors to trick the AI agents. They can hide invisible text (white or tiny font), they can include a compromised file on their website, or any other method. The goal is for the model to interpret data from the website as a prompt and follow their instructions. The agentic AI will then take actions that the target did not intend.

What are they trying to achieve? State the security property you intend to violate.

> The attacker is attempting to get the Agentic AI to leak the victim’s API keys or information from their calendar via email. Leaking this information would breach confidentiality.

What are you not claiming? A result without a boundary cannot be evaluated.

> We are not claiming to be able to breach the AI models and gain information from their development (host server information, training information,

etc.). The only information we will be attempting to retrieve will be provided to the AI model by the victim themselves.

Scope

- What you will touch, and what you will not. Name the machines, accounts, and repositories, not categories.
    - We will be using n8n with the predetermined flag and linked accounts created entirely for this project. We will be touching a website hosted by the team and attempting to send the flag to an email associated with the website. This website will not be exposed to the Internet. This is so we do not unintentionally perform an attack on any live Agentic AI models.
- Where the work runs: localhost, a private VM, or behind authentication.
    - The work will run on a locally hosted website. We will be using n8n to scan our hosted website and attempt to hijack the AI model into sending the predetermined flag retrieved from the user of the LLM to the owner of the website.
- Track A: whose API keys and accounts you will use.
    - We will be using James' API keys for Ollama and ChatGPT

AI Use Appendix

AI was not utilized in the making of this document.